

CS-AML

API Specification

Version 0.1

Purpose

Normative HTTP API baseline for CS-AML MVP 0.1. It defines resource conventions, request/response envelopes, versioning, authorization behavior, filtering, pagination, concurrency, idempotency, uploads, search, graph projections, review/dissemination operations, errors, audit correlation and verification expectations.

Core API axiom

The API SHALL expose canonical data and authorized derived views without erasing provenance, uncertainty, version history or permission boundaries. It SHALL NOT convert candidate, reconstructed, hypothetical, inferred or derived data into stronger canonical truth through transport semantics.

Status: Normative API contract baseline for MVP 0.1

Dependencies: Framework · Data Model · SRS · Technology Architecture · Frontend Architecture · Security Controls

Document Control

Attribute	Value
Document ID	CSAML-API-0.1
Version	0.1
Status	Normative API baseline
Primary audience	Backend Engineer, Frontend Engineer, QA, Security Reviewer, Integration Engineer
Protocol	HTTPS + JSON; multipart/streaming where file transfer requires it
Reference style	Resource-oriented REST API with explicit action endpoints for workflow decisions
Normative verbs	SHALL / MUST / SHOULD / MAY

1. Scope and Boundary

This document defines the externally observable API contract for the CS-AML MVP. It does not require a particular backend framework or database schema. The canonical server implementation MAY use Django REST Framework or equivalent, but clients SHALL rely on the documented API rather than backend internals.

Authorization rule

Every API read, count, search result, relationship traversal, export candidate and mutation SHALL be permission-aware. UI behavior cannot broaden access.

2. API Design Principles

ID	Principle	Requirement
API-P01	Canonical resource first	Stable IDs identify canonical resources independent of UI route context.
API-P02	Context explicit	Case context, version and projection scope are explicit rather than inferred from browser state.
API-P03	Provenance preserved	Material analytical records expose provenance/evidence references appropriate to authorization.

ID	Principle	Requirement
API-P04	Uncertainty preserved	Unknown, disputed, candidate, reconstructed and hypothetical states are first-class values.
API-P05	Non-disclosing authorization	Denied requests SHALL not leak protected resource existence/content beyond policy.
API-P06	Version-aware mutation	Conflicting updates fail explicitly; no last-write-wins for material canonical records.
API-P07	Derived is labeled	Search, graph, path, summary and analytical projections are identified as derived/rebuildable.
API-P08	Audit correlation	Material requests have correlation/request IDs and auditable actor/action context.
API-P09	Predictable errors	Machine-readable error code + safe human message + field errors where relevant.
API-P10	Evolution controlled	Breaking changes require versioning/migration strategy.

3. Base URL, Versioning and Media Type

```
https://csaml.example.org/api/v1/
Accept: application/json
Content-Type: application/json
X-Request-ID: <optional-client-correlation-id>
```

- Initial major version SHALL be `/api/v1/`.
- Breaking field removals/semantic changes require a new major API version or documented compatibility period.
- Additive optional fields MAY be introduced within v1.
- Clients SHALL ignore unknown response fields unless schema validation explicitly disallows them for a security reason.
- API schema/OpenAPI document SHOULD be versioned with application releases.

4. Authentication and Principal Context

Concern	Requirement
Authentication	OIDC-authenticated session/bearer mechanism approved by security architecture.

Concern	Requirement
Principal	Server resolves user/service identity; client-submitted actor identity is not trusted.
MFA	Required claims/policy enforced server-side for sensitive actions where configured.
Service account	Distinct non-human principal; least privilege; no shared analyst identity.
Logout/revocation	Subsequent requests fail according to session/token policy.
Impersonation	Not supported in MVP unless separately controlled/audited.

5. Common Headers and Correlation

Header	Direction	Use
Authorization / session cookie	Request	Authentication according to deployment.
X-Request-ID	Both	Correlation ID; server generates when absent.
ETag	Response	Optional HTTP representation version token.
If-Match	Request	Concurrency guard for version-aware mutation.
Idempotency-Key	Request	Required/recommended for selected repeat-sensitive operations.
Retry-After	Response	Rate limit/async polling guidance.
Content-Disposition	Response	Safe filename for export/download.

6. Common Resource Envelope

```
{
  "id": "uuid",
  "object_type": "entity",
  "schema_version": "1.0",
  "record_version": 7,
  "status": "active",
  "classification": "RESTRICTED",
  "created_at": "2026-10-07T10:00:00Z",
  "created_by": {"id": "...", "display_name": "..."},
  "updated_at": "2026-10-07T11:12:00Z",
  "links": {...},
  "capabilities": ["read", "update", "link"]
}
```

```
}
```

Capabilities

`capabilities` MAY help the UI render permitted actions, but SHALL NOT replace server authorization. Capabilities are contextual and may change between requests.

7. Naming and Resource Conventions

Rule	Convention
Collection names	Plural kebab-case or consistent plural nouns: `/cases`, `/entities`, `/value-flows`.
IDs	Opaque stable UUID-like identifiers; clients do not parse meaning from IDs.
Timestamps	ISO 8601 UTC in transport; original timezone may be additional metadata.
Enums	Stable machine values; user-facing localized labels are separate.
Unknown	Use `null`/explicit status per schema; never substitute 0/false/empty string when semantically different.
Money	Amount + currency; ranges preserve min/max/approximate/original value semantics.
Dates	Precision field accompanies partial/approximate dates where domain requires it.
Relationships	First-class resource, not hidden nested-only edge.

8. Pagination, Sorting and Filtering

```
GET /api/v1/entities?case_id=...&type=COMPANY&status=confirmed&sort=-updated_at&page[size]=50&page[after]=...
```

Concern	Baseline
Pagination	Cursor-based SHOULD be preferred for mutable large collections; page-number MAY be used for stable admin lists.
Page size	Default 50; max configurable. Server MAY lower for expensive resources.
Sorting	Explicit allowlist only; deterministic secondary sort.

Concern	Baseline
Filtering	Typed documented filters; no arbitrary raw SQL/query expressions.
Facets	Server computes permission-aware facets/counts.
Total count	MAY be omitted/approximate for expensive permission-filtered queries; semantics documented.
Search query	Input length/rate limits apply; results never reveal unauthorized counts/snippets.

9. Error Model

```
{
  "error": {
    "code": "VERSION_CONFLICT",
    "message": "The record changed after you opened it.",
    "request_id": "req_...",
    "details": {"current_record_version": 8},
    "field_errors": {}
  }
}
```

HTTP	Example code	Semantics
400	INVALID_REQUEST	Malformed/semantically invalid request not tied to one field.
401	AUTHENTICATION_REQUIRED	No valid authenticated principal.
403/404	ACCESS_DENIED / NOT_FOUND	Deployment/policy chooses non-disclosing behavior consistently.
409	VERSION_CONFLICT / STATE_CONFLICT	Stale version or workflow state prevents mutation.
412	PRECONDITION_FAILED	If-Match/ETag failed.
422	VALIDATION_FAILED	Field/domain validation.
429	RATE_LIMITED	Request rate or expensive operation threshold exceeded.
500	INTERNAL_ERROR	Safe generic message; request ID for support.
503	DEPENDENCY_UNAVAILABLE	Temporary backend dependency failure.

Error safety

Error payloads SHALL not include raw SQL, stack traces, filesystem paths, evidence snippets, protected-source identity or authorization-policy internals.

10. Concurrency and Record Versioning

- Material mutable resources SHALL expose `record\_version` or equivalent concurrency token.
- Update requests SHALL send expected version through body and/or `If-Match`.
- On mismatch, API SHALL return conflict and current safe metadata needed for recovery; it SHALL NOT silently overwrite.
- Approvals, merges, dissemination and assessment finalization SHALL validate both version and current workflow state.
- Immutable/audit resources reject ordinary update/delete methods.

```
PATCH /api/v1/assessments/{id}
If-Match: "7"
{ "record_version": 7, "judgement": "..." }

→ 409 VERSION_CONFLICT if current version is 8
```

11. Idempotency

Operation	Idempotency requirement
Normal PATCH with version token	Version conflict protection generally sufficient.
Create case/entity	Client-generated idempotency key SHOULD be supported when retries may duplicate creation.
Evidence ingest finalization	Idempotency key REQUIRED/recommended to avoid duplicate completion after retry.
Merge/unmerge	Server action ID/idempotency key SHOULD prevent repeated action.
Approve review/dissemination	Repeat submission SHALL return same completed decision or safe conflict, not duplicate decision.
Export package generation	Idempotency key SHOULD tie retry to same approved package request.

12. Case and Workflow API

Method	Endpoint	Purpose
GET	/cases	Authorized case register.
POST	/cases	Create case.

Method	Endpoint	Purpose
GET	/cases/{caseId}	Canonical case detail.
PATCH	/cases/{caseId}	Version-aware case update.
GET	/cases/{caseId}/charter	Current charter + version history links.
POST	/cases/{caseId}/charter/versions	Create new charter version.
GET	/cases/{caseId}/gates	Lifecycle gates.
POST	/cases/{caseId}/gates/{gateId}/submit	Submit gate for decision.
POST	/cases/{caseId}/gates/{gateId}/approve	Independent approval action.
POST	/cases/{caseId}/gates/{gateId}/reject	Reject/return with rationale.
GET	/cases/{caseId}/tasks	Tasks.
POST	/cases/{caseId}/tasks	Create task.
GET	/cases/{caseId}/activity	Material case activity projection.

13. Source, Evidence and File API

Method	Endpoint	Purpose
GET/POST	/sources	Register/query sources.
GET/PATCH	/sources/{sourceId}	Source detail/update.
GET	/evidence	Authorized evidence library.
POST	/evidence/uploads	Initiate upload session.
PUT/POST	/evidence/uploads/{uploadId}/content	Stream/upload bytes or receive pre-signed target according to deployment.
POST	/evidence/uploads/{uploadId}/complete	Finalize immutable evidence record and hash.
GET	/evidence/{evidenceId}	Evidence metadata.
GET	/evidence/{evidenceId}/content	Authorized content stream/download; supports range where safe.
POST	/evidence/{evidenceId}/verify-integrity	Recompute/verify integrity.
POST	/evidence/{evidenceId}/extracts	Create citation/extract.
GET	/evidence/{evidenceId}/lineage	Original/derivative lineage.
POST	/evidence/{evidenceId}/derivatives	Register approved derivative metadata/output.

Evidence invariant

File upload success SHALL NOT by itself mean evidence is complete. The completion endpoint SHALL only succeed after required metadata, storage write and integrity record succeed atomically or with documented compensating behavior.

14. Entity, Relationship and Asset API

Method	Endpoint	Purpose
GET/POST	/entities	Authorized entity search/register/create.
GET/PATCH	/entities/{entityId}	Canonical entity detail/update.
GET	/entities/{entityId}/identifiers	Identifiers/aliases with provenance.
GET	/entity-match-candidates	Candidate duplicates.
POST	/entity-match-candidates/{id}/decisions	Mark same/distinct/unresolved/defer.
POST	/entities/merge	Version-aware merge action.
POST	/entity-merges/{mergeId}/unmerge	Controlled reversal.
GET/POST	/relationships	First-class relationships.
GET/PATCH	/relationships/{relationshipId}	Relationship detail/update.
GET/POST	/assets	Asset registry.
GET/PATCH	/assets/{assetId}	Asset detail/update.

15. Timeline and Value Flow API

Method	Endpoint	Purpose
GET/POST	/events	Events with temporal precision.
GET	/timeline	Derived timeline projection scoped by case/entity/date.
GET/POST	/value-flows	ValueFlow resources.
GET/PATCH	/value-flows/{flowId}	Flow detail/update.
POST	/value-flows/{flowId}/legs	Add version-aware flow leg.
GET	/value-flow-view	Derived graph/list projection for workspace.

Method	Endpoint	Purpose
GET	/value-flow-legend	Optional semantic metadata/labels for clients.

Flow semantics

Every ValueFlow response SHALL carry its epistemic class: DIRECT, DOCUMENTED, RECONSTRUCTED or HYPOTHETICAL. No endpoint may collapse these into a generic “transaction” representation.

16. Typology, Hypothesis and Assessment API

Method	Endpoint	Purpose
GET	/typologies	Versioned typology catalogue.
GET	/typologies/{typologyId}	Typology version/detail.
GET/POST	/indicators	Evidence-linked indicators/counter-indicators.
GET/POST	/typology-matches	Case typology worksheets.
GET/POST	/hypotheses	Competing hypotheses.
PATCH	/hypotheses/{id}	Version-aware update.
GET/POST	/intelligence-gaps	Explicit unknowns.
GET/POST	/assessments	Draft/versioned assessments.
POST	/assessments/{id}/finalize	Controlled finalization action.
GET	/assessments/{id}/provenance	Backward trace to hypotheses/facts/evidence.

17. Search API

GET /api/v1/search?q=company+x&type=entity,evidence&case_id=...&status=...&page[size]=25

Response element	Rule
results	Only authorized canonical/derived references.
snippet	Permission-safe; SHALL not reveal hidden protected content.
facets	Permission-filtered counts.

Response element	Rule
rank/score	Search relevance only; SHALL not be labeled risk/suspicion.
source	Canonical object type + stable ID.
projection marker	Derived/extracted text result identifies derivative source when applicable.

18. Graph API

```
POST /api/v1/graph/query
{
  "case_id": "...",
  "seed_entities": ["..."],
  "relationship_types": ["OWNS", "DIRECTOR_OF"],
  "depth": 2,
  "include_value_flows": true
}
```

Element	Requirement
Nodes	Canonical object references with authorized display metadata.
Edges	Relationship/ValueFlow IDs, type, dates, confidence/status, provenance refs as authorized.
Derived metrics	Explicitly marked derived with algorithm/version/input scope.
Path query	Output means path in authorized graph, not proof of culpability/causality.
Limits	Server enforces depth/node/edge budgets and rate limits.
Rebuildability	Graph projection is never the sole canonical source.

19. Product, Review and Dissemination API

Method	Endpoint	Purpose
GET/POST	/products	Intelligence product library/create.
GET/PATCH	/products/{productId}	Current draft/version-aware edit.
GET	/products/{productId}/versions	Version history.
POST	/products/{productId}/submit-review	Freeze/submit version.
GET	/reviews	Review queue.

Method	Endpoint	Purpose
GET	/reviews/{reviewId}	Review workspace data.
POST	/reviews/{reviewId}/request-changes	Decision action.
POST	/reviews/{reviewId}/approve	Independent approval.
POST	/reviews/{reviewId}/reject	Reject with rationale.
POST	/disseminations	Create dissemination request.
POST	/disseminations/{id}/approve	Authorize recipient/purpose/package scope.
GET	/disseminations/{id}/export-candidates	Authorized selectable export objects.
POST	/disseminations/{id}/exports	Generate export package.
GET	/sharing-log	Immutable authorized sharing records.

20. Administration and Audit API

Method	Endpoint	Purpose
GET/POST	/vocabularies	Controlled vocabulary management.
GET/POST	/retention-policies	Retention policy management.
GET/PATCH	/case-memberships/{id}	Case membership/access administration.
GET	/audit-events	Permission-aware immutable audit explorer.
GET	/system/info	Build/schema/API version and safe diagnostics.
GET	/system/health	Health check; public/private detail according to deployment.
GET	/capabilities	Optional principal/deployment capability summary.

21. Protected Source API Boundary

- Protected-source identity SHALL use dedicated endpoints and authorization scopes separated from ordinary source/evidence APIs.
- Ordinary evidence/source payloads SHALL reference protected source through non-identifying handles where needed.
- Protected-source identity SHALL not be included in generic search, graph, audit payloads, export candidates or global capability summaries.
- API documentation/examples SHALL use synthetic values and SHALL not encourage clients to cache protected identity broadly.

/api/v1/protected-sources/... # restricted namespace; not part of ordinary analyst client bundle by default

22. Asynchronous Jobs

Operation	Async?	Pattern
Large evidence processing	YES	Return 202 + job resource.
OCR/derivative generation	YES in Phase 2	Job status + derived artifact on completion.
Large export package	YES	202 + job; final download only after approval remains valid.
Graph projection rebuild	YES	Admin/operator job.
Normal CRUD	NO	Synchronous transaction.
Search	NO	Synchronous with timeout/rate limits.

```
202 Accepted
{ "job": { "id": "job_...", "status": "queued", "poll_url": "/api/v1/jobs/job_..." } }
```

23. File Transfer and Content Safety

- Uploads SHALL enforce server-side size/type policy and SHALL not trust browser MIME/extension alone.
- Original filenames are metadata; object storage keys are opaque.
- Content downloads SHALL use safe Content-Type/Content-Disposition and authorization on every request.
- Range requests MAY be supported for large evidence viewing.
- Active documents SHOULD be served in a way that prevents execution in the CS-AML origin context.
- Malware scanning/quarantine hooks SHALL not silently rewrite the original evidence; quarantine state is metadata/workflow.

24. Bulk Operations

Bulk action	MVP
Bulk tag/classify low-risk metadata	MAY support with per-object authorization/results.
Bulk evidence export	Only through approved dissemination/export workflow.
Bulk entity merge	NOT supported.
Bulk deletion	NOT supported for ordinary analyst.
Bulk relationship import	MAY be later; each record requires provenance/validation.

Bulk action	MVP
Bulk audit retrieval	Privileged, paginated/rate-limited.

25. Rate Limiting and Abuse Controls

- Authentication, search, graph traversal, export generation and upload endpoints SHOULD have differentiated limits.
- Rate-limit responses use 429 and MAY include Retry-After.
- Limits SHALL not reveal hidden resource counts.
- Privileged/bulk APIs require stronger authorization and audit.
- Automated clients/service accounts SHOULD have separately identifiable quotas.

26. API Security Requirements

ID	Requirement
API-SEC-01	TLS required outside explicitly isolated local development.
API-SEC-02	All object access is authorized server-side using role + case/context + classification + need-to-know as applicable.
API-SEC-03	Object IDs are not authorization secrets.
API-SEC-04	Mass assignment is prevented by explicit writable-field schemas.
API-SEC-05	Input validation and output encoding are applied consistently.
API-SEC-06	CSRF protections apply when cookie-based browser auth is used.
API-SEC-07	CORS is explicit and minimal.
API-SEC-08	Sensitive payloads are excluded/redacted from routine access logs.
API-SEC-09	Export/download endpoints re-check authorization at retrieval time where appropriate.
API-SEC-10	Schema/docs do not expose privileged endpoints to unauthorized clients as an access control mechanism; actual authorization still applies.

27. Audit Semantics

Action	Audit expectation
Create/update canonical object	Actor, action, object, version, timestamp, request ID; material before/after reference.
Entity merge/unmerge	Decision/rationale/evidence references + topology-impact record.
Assessment finalize	Version, author, confidence, gate state.
Review decision	Reviewer, product/version, decision, rationale.
Dissemination approval/export	Recipient/purpose/package/version/included object manifest.
Failed high-impact action	Security/audit event where policy requires.
Read access	Routine reads MAY be logged selectively; protected-source/access-sensitive reads SHOULD have stronger audit policy.

28. API Schema and OpenAPI Requirements

- An OpenAPI 3.1-equivalent schema SHOULD be generated/published for v1.
- Schemas SHALL identify required/nullable fields explicitly.
- Enums SHALL include stable machine values and descriptions.
- Examples SHALL use synthetic data.
- High-impact action endpoints SHALL document preconditions and conflict/error codes.
- Client TypeScript types MAY be generated from the schema; generated code SHALL not replace domain semantics documentation.

29. Compatibility and Deprecation

Change	Policy
Add optional response field	Compatible.
Add enum value	Potentially compatible only if clients are required to handle unknown values safely; announce.
Rename/remove field	Breaking; new major or migration window.
Change meaning of existing field	Breaking even if JSON shape unchanged.
Endpoint deprecation	Mark in schema/docs, announce removal version/date, provide replacement.
Controlled vocabulary change	Vocabulary versioning; historical records retain original term semantics.

30. Verification and Contract Testing

Test class	Required verification
Schema	Responses validate against OpenAPI/schema.
Authorization	Positive and negative tests for case membership/classification/protected source.
Non-disclosure	Unauthorized IDs/search/facets do not reveal hidden resource metadata.
Concurrency	Stale writes return conflict and do not overwrite.
Idempotency	Retries do not duplicate selected actions.
Evidence	Upload/finalize/hash/content authorization and lineage.
Analytical semantics	Flow classes, unknown/range values, candidate/disputed states preserved.
Review/dissemination	Independent approval/preconditions/export manifest enforced.
Audit	Material actions create expected correlated audit records.
Performance	P0 list/search/graph endpoints meet documented MVP targets.

31. API Definition of Done

Area	Done when
Contract	Endpoint/resource has documented schema, methods, authorization context and error cases.
Traceability	Mapped to feature/SRS requirement.
Authorization	Positive/negative/non-disclosing tests pass.
Versioning	Mutable material resource has conflict semantics.
Audit	Material action emits required audit event/correlation.
Frontend	Generated/manual client integration handles loading/error/conflict states.
Docs	OpenAPI/examples updated with synthetic data.
Security	Input/output/file/download controls pass review.
Regression	Contract tests included in CI.

Annex A — Canonical Resource Baseline

Domain	Resources
Case	Case, InvestigationQuestion/CharterVersion, Gate, Task, CaseActivity projection
Evidence	Source, EvidenceItem, EvidenceExtract, Derivative/Lineage
Identity	Entity, Identifier/Alias, MatchCandidate, MergeDecision
Relations/assets	Relationship, OwnershipInterest, ControlAssertion, Asset
Time/value	Event, Timeline projection, ValueFlow, ValueFlowLeg
Analysis	Indicator, Typology, TypologyMatch, Hypothesis, IntelligenceGap, Assessment
Products	IntelligenceProduct, ProductVersion, Review, Dissemination, ExportPackage, SharingLog
Governance	Vocabulary, RetentionPolicy, CaseMembership, AuditEvent, Job

Annex B — Request Review Checklist

- Is the canonical resource and case/context scope explicit?
- Does the endpoint preserve unknown/inference/candidate/value-flow class semantics?
- What authorization and non-disclosure behavior applies?
- Is a version token/precondition required?
- Could a retry duplicate a high-impact action; is idempotency needed?
- What audit event/correlation must be emitted?
- Could error details leak protected content?
- Are pagination/filter/sort fields allowlisted?
- Does the response include only the minimum authorized data needed?
- Is this canonical data or a derived projection, and is that distinction explicit?